

第七讲 DNS协议（域名解析协议）

学习任务

- ✓ 了解域名结构
- ✓ DNS查询过程
- ✓ 分析流 实施DNS欺骗 再分析

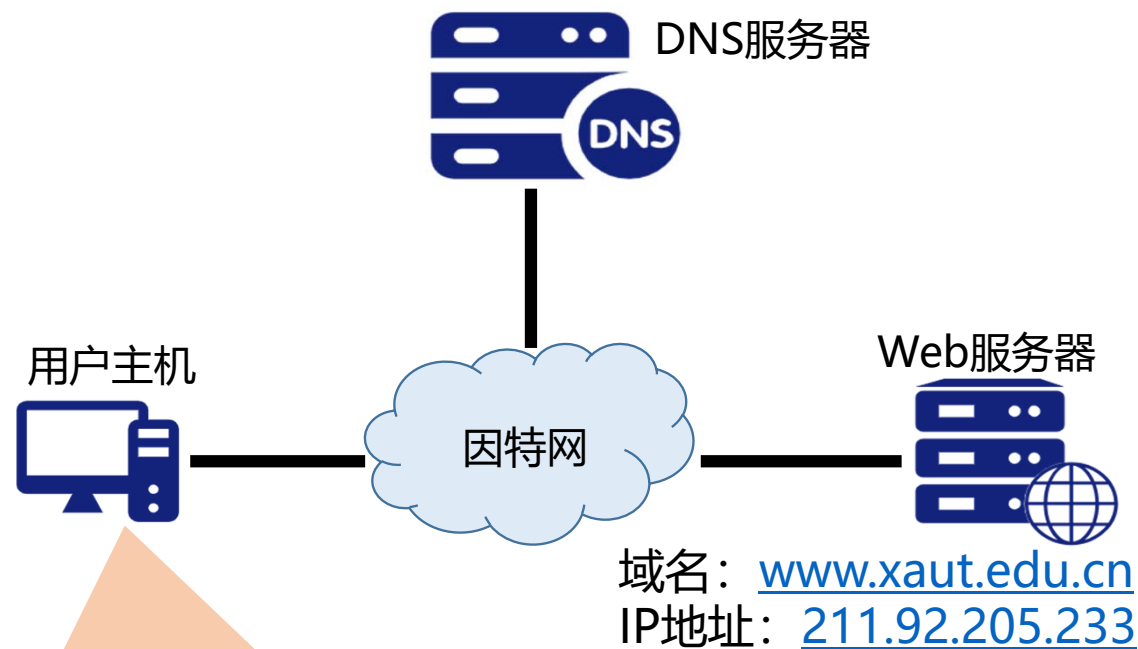
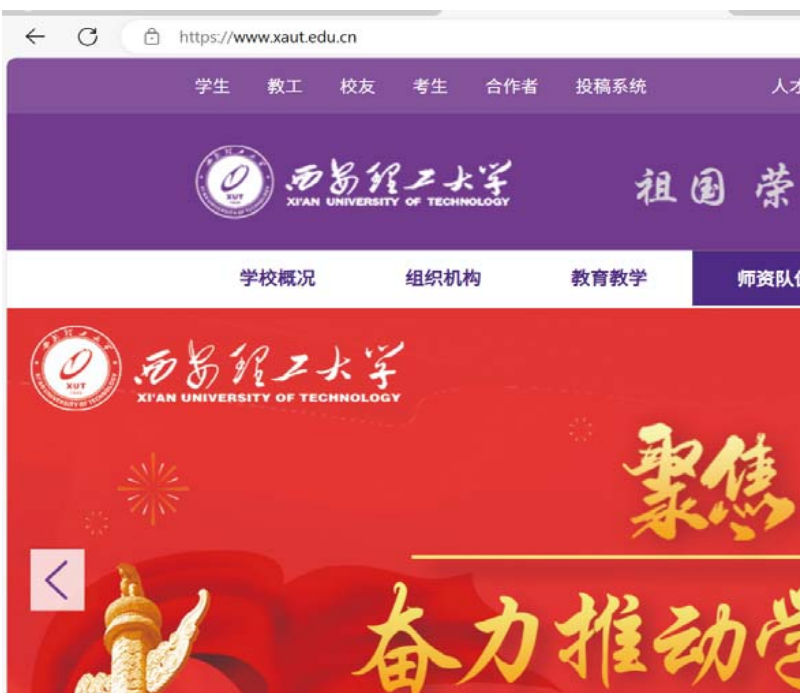
DNS基本知识

基本概念：

- ✓ DNS(domain name system)域名系统，作为将域名与IP地址的相互映射关系存放在一个分布式的数据库
- ✓ DNS使用是UDP的53端口
- ✓ 域名：由ICANN机构统一管理

第七讲 DNS协议

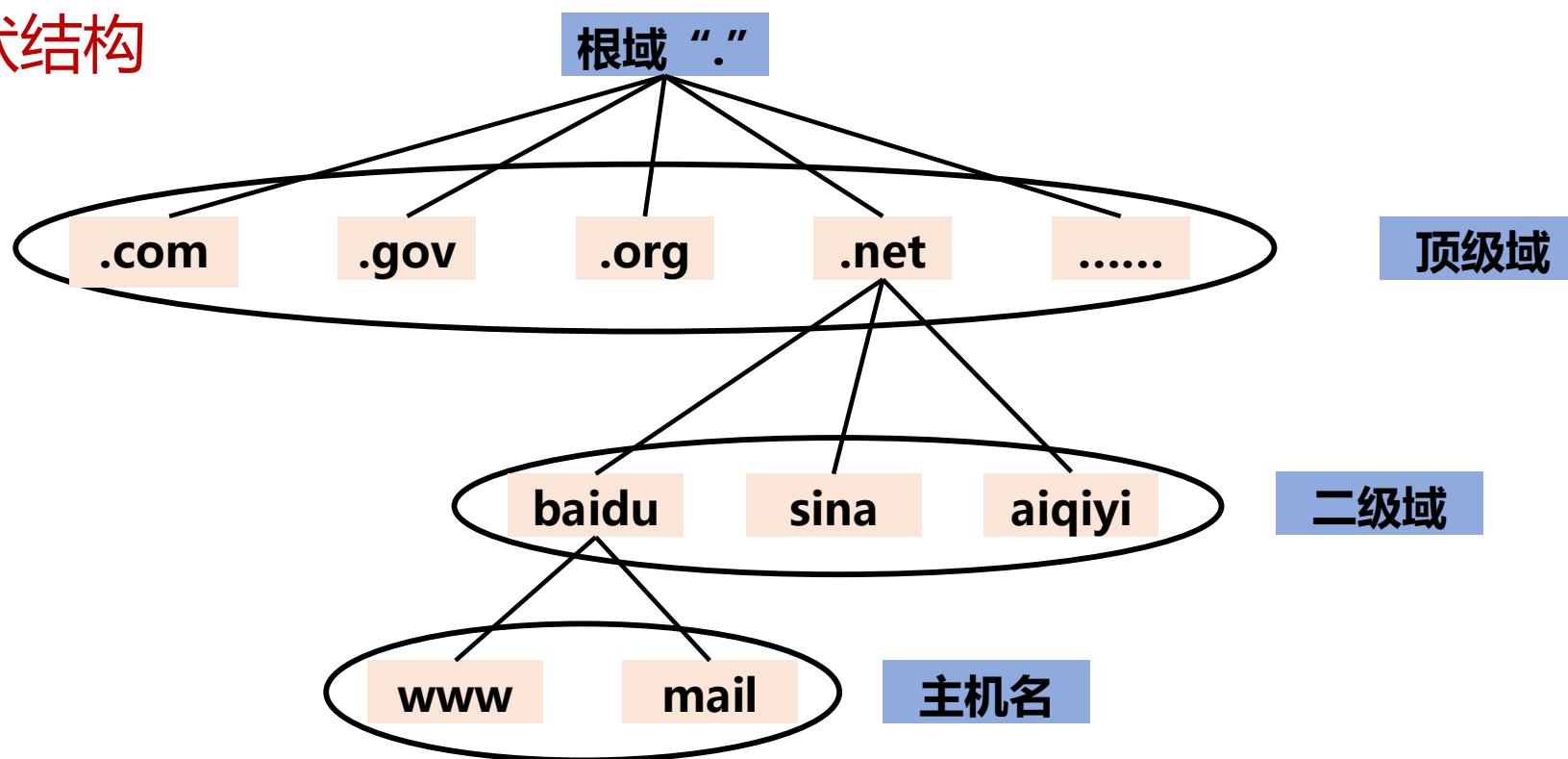
DNS工作原理



在高速缓存中查找
www.xaut.edu.cn 对应的IP地址
若未找到!

域名空间结构

域名空间：树状结构



域名空间结构

树状结构根域：(全世界只有13台根域服务器)

顶级域：(主要用于区分域名的用途)

组织类

com 商业

edu 教育和学校

org 社会非盈利性组织

国家/地区域名

cn 中国

hk 香港

us 美国

uk 英国

域名空间结构

二级域:

woniu.com

www.woniu.com

mail.woniu.com

域名查询过程

✓ 递归查询

✓ 迭代查询

首选DNS服务器



客户端



Web服务器



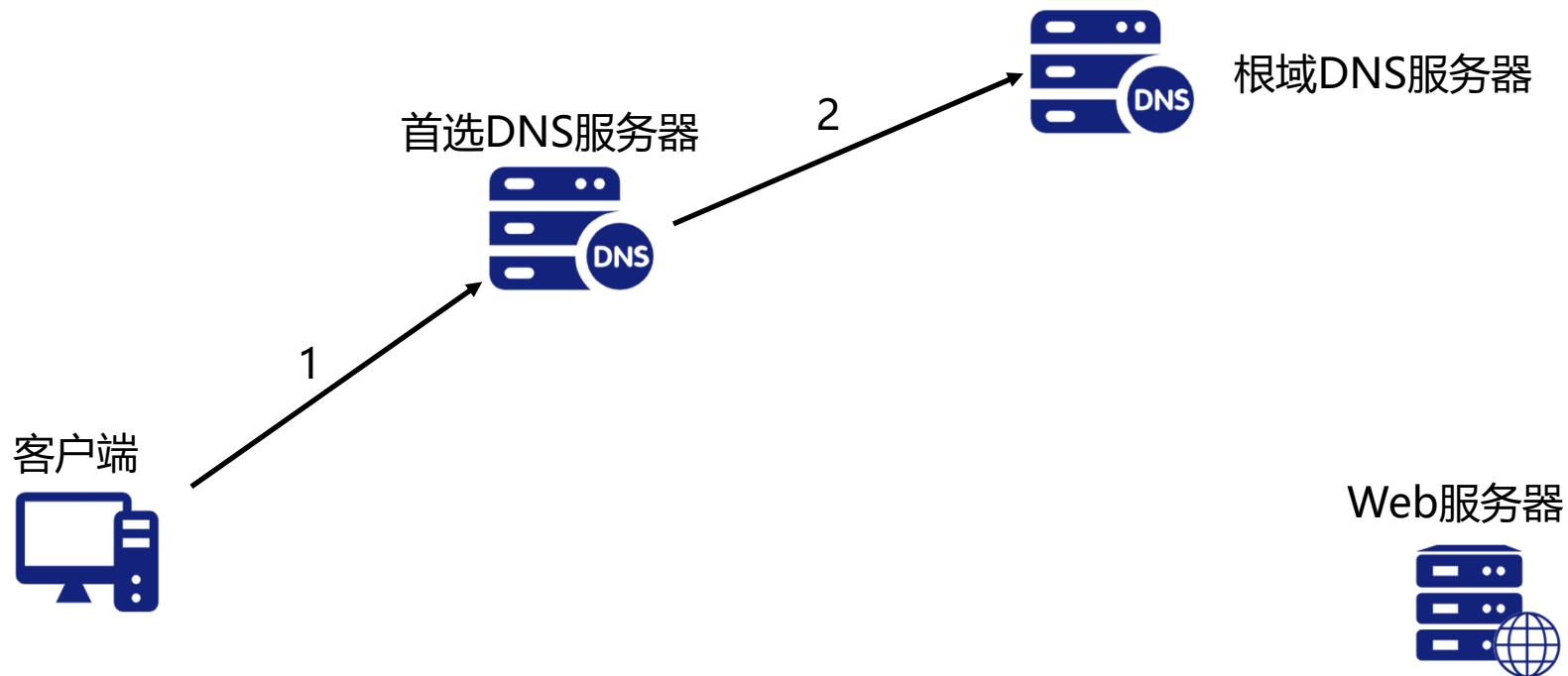
www.baidu.com

域名查询过程



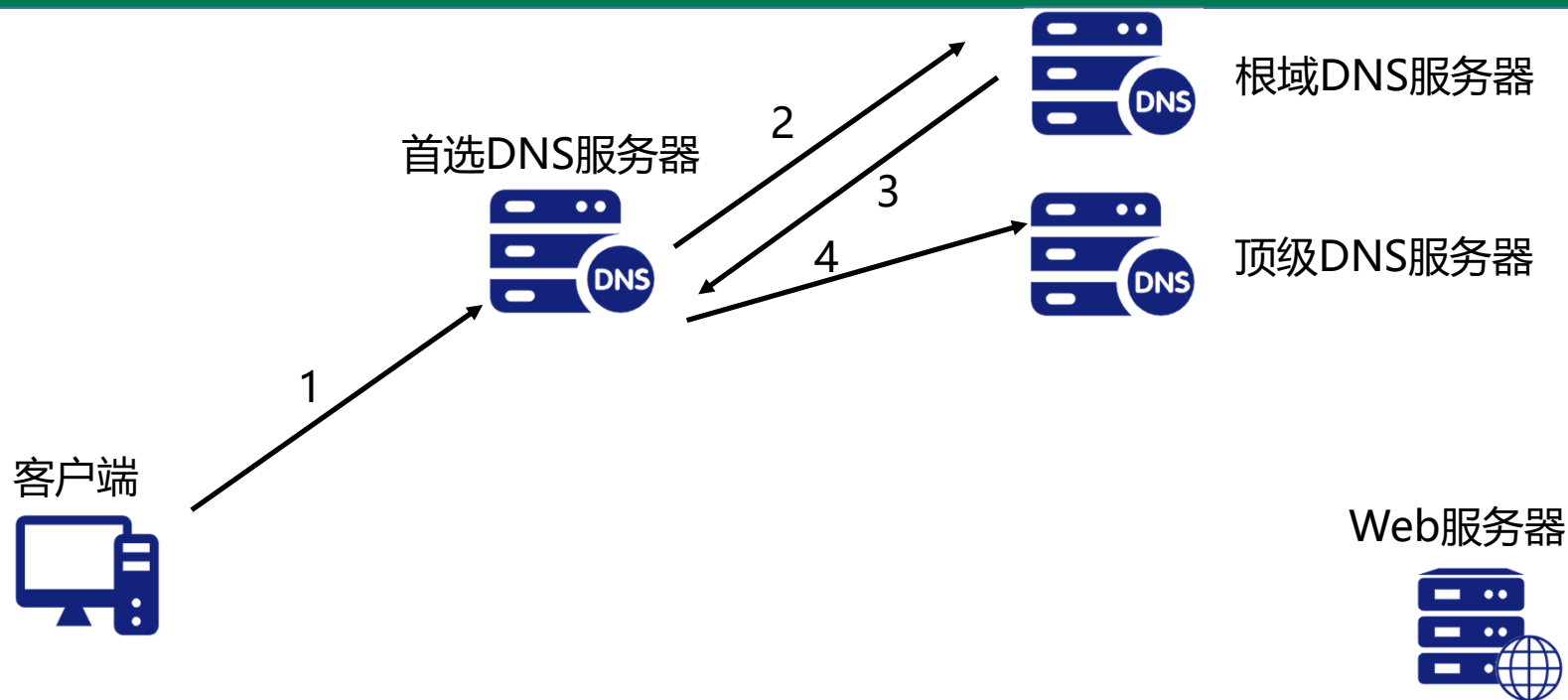
- ✓ 客户机想要访问 `www.baidu.com`, 根据自己的TCP/IP参数, 向自己的首选DNS服务器发送DNS请求; 如果直接可以找到`www.baidu.com`的IP地址信息(直接响应给客户机)

域名查询过程



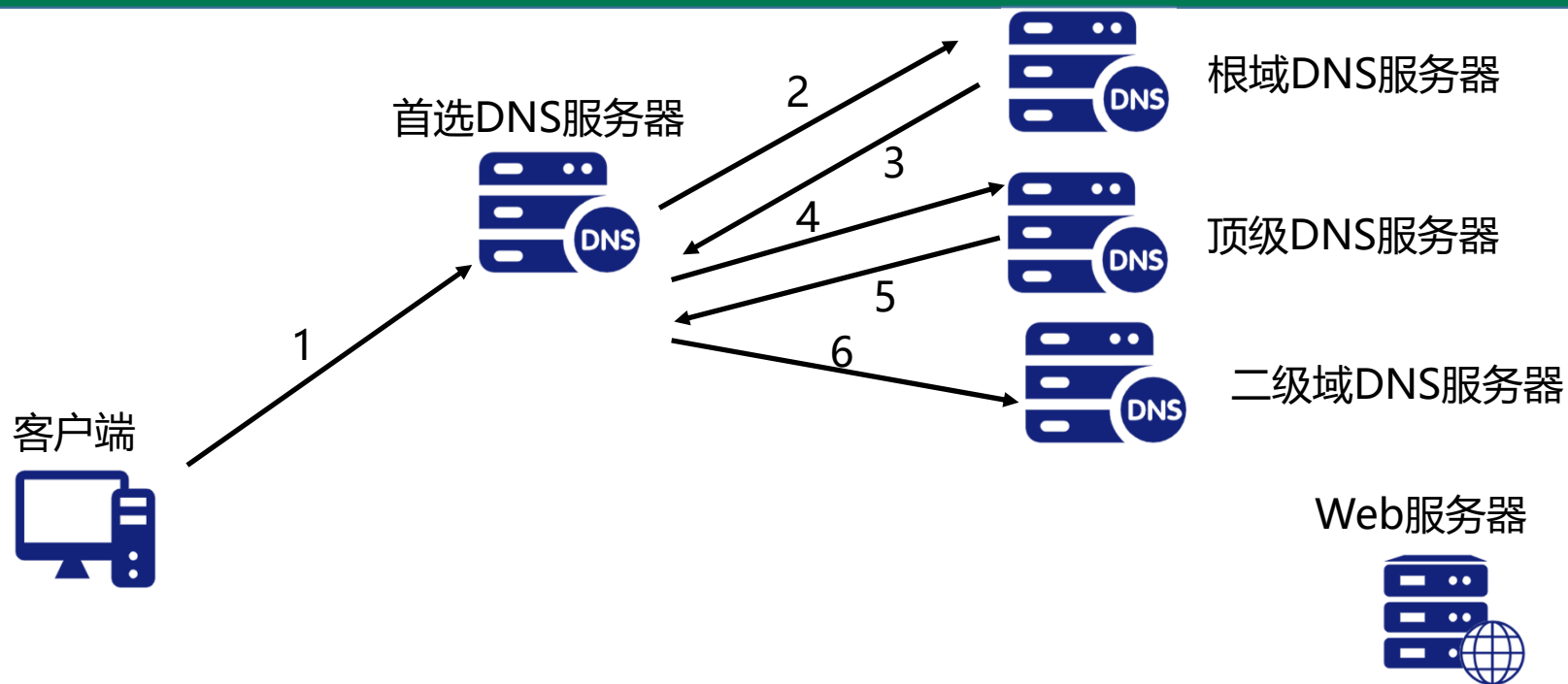
- ✓ 首选DNS收到客户机的请求后，会去查询自己的区域文件，找不到 `www.baidu.com` 的IP地址信息(将请求转发到根域服务器，需要配置根提示)；

域名查询过程



- ✓ 根域服务器收到请求后，由于根域服务器只维护顶级域服务器信息，会响应顶级域服务器IP(com)，首选DNS根据根域服务器响应的信息，将请求转发到com顶级域

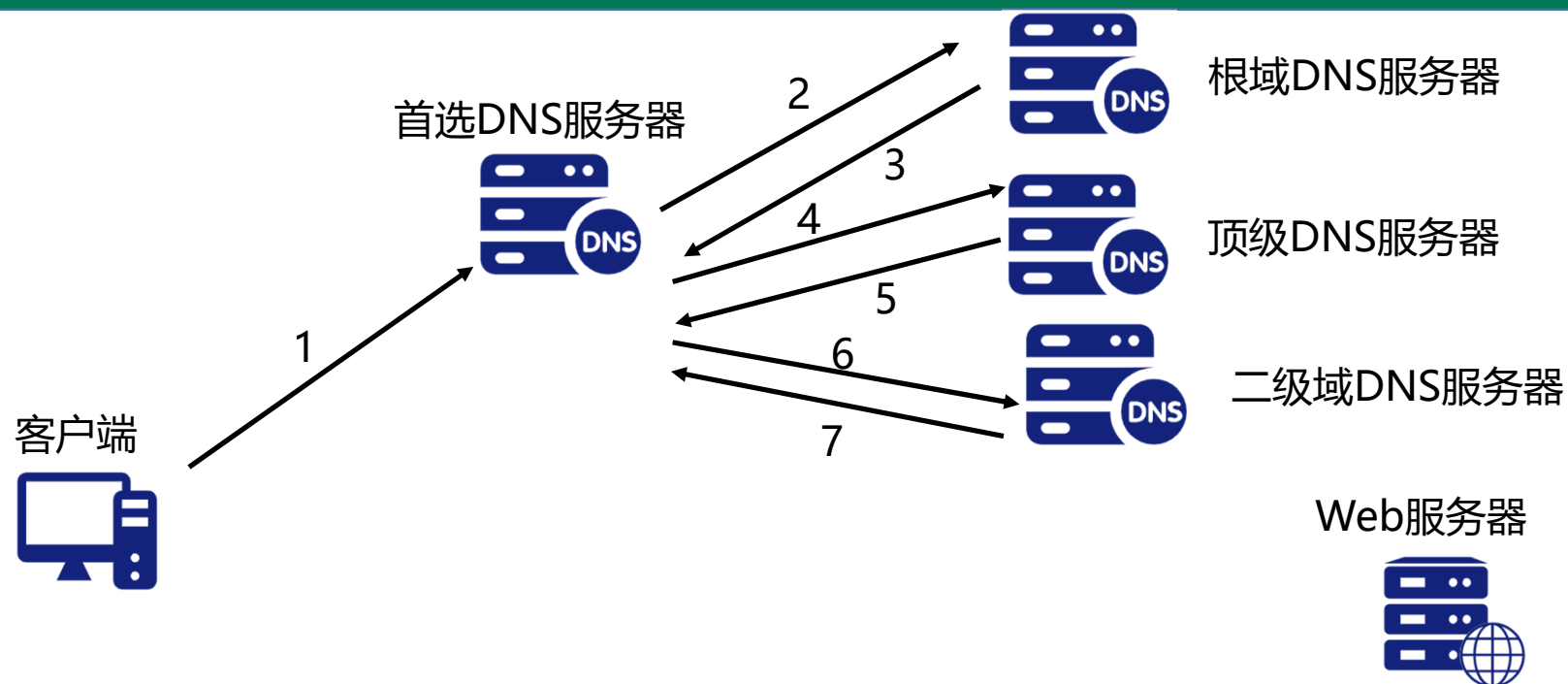
域名查询过程



✓ 顶级域务器收到请求，由于com顶级域服务器只维护二级域信息，会响应二级域服务器

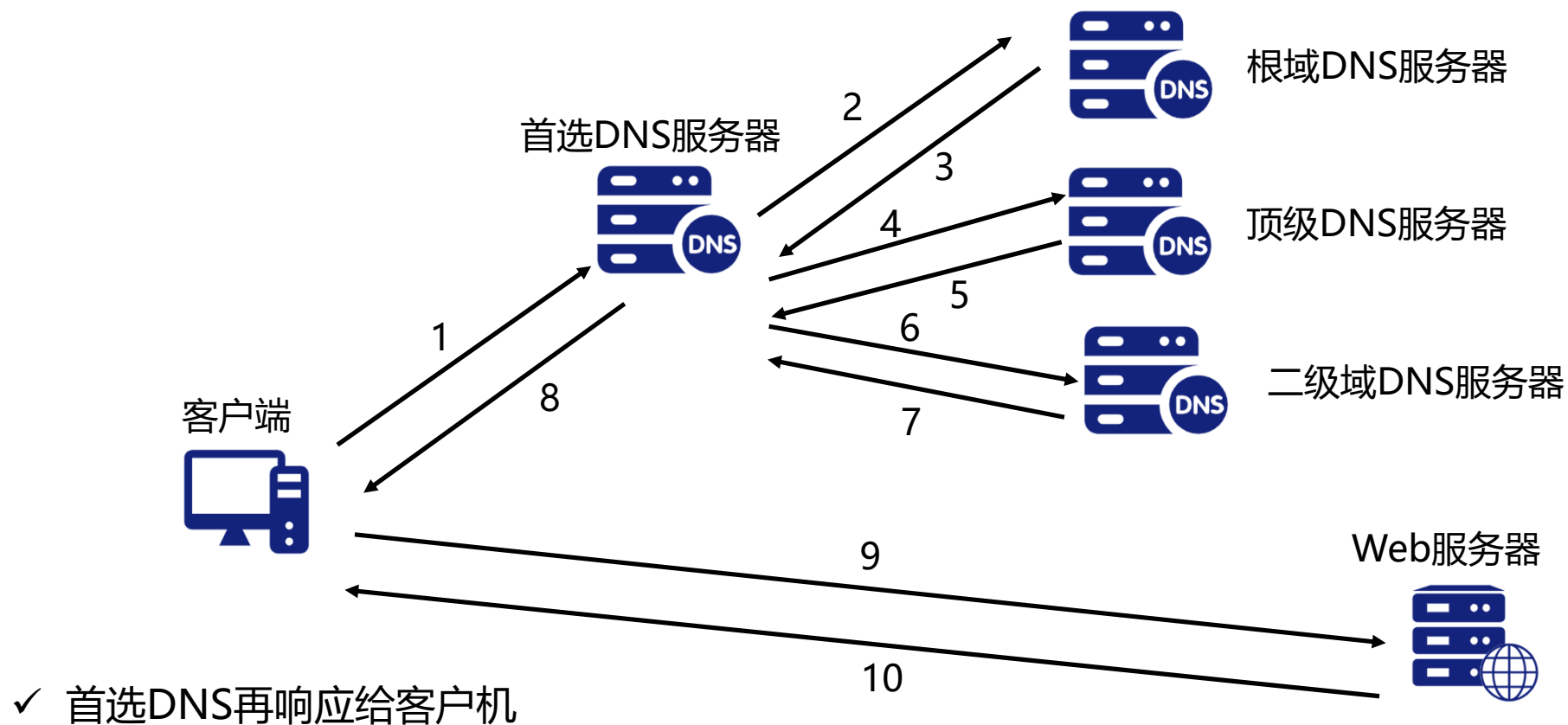
IP(baidu.com)，首选DNS根据顶级服务器响应的信息，将请求转发到二级域服务器 IP(baidu.com)

域名查询过程



- ✓ baidu.com二级域收到请求， baidu.comDNS服务器里面维护的是baidu.com区域所有的主机信息，包含了www.baidu.com的信息，直接将www.baidu.com的IP地址响应给首选DNS

域名查询过程



域名查询过程

✓ 递归查询

当客户机请求自己的首选DNS服务器，首选DNS服务器上有域名记录信息，直接响应给客户机（根据上图所示，第1步和第8步就是递归查询）

✓ 迭代查询

首选DNS服务器没有域名记录信息，通过一步一步去请求根域服务器、顶级域服务器、二级域服务器，最终找到对应的域名记录信息

DNS报文格式



DNS报由三部分构成：首部、查询问题区域和资源记录区域

第七讲 DNS协议



DNS报文格式

TCP.pcapng [ESW1 FastEthernet0/0 to R1 FastEthernet0/0]

```
> Frame 7: 137 bytes on wire (1096 bits), 137 bytes captured (1096 bits) on interface \Device\NPF_{00C0FC05-97D0-4...
> Ethernet II, Src: RuijieNetwor_51:32:56 (c0:b8:e6:51:32:56), Dst: Intel_ef:2d:10 (18:56:80:ef:2d:10)
> Internet Protocol Version 4, Src: 202.200.123.2 (202.200.123.2), Dst: 10.103.123.219 (10.103.123.219)
> User Datagram Protocol, Src Port: 53, Dst Port: 50047
▼ Domain Name System (response)
  Transaction ID: 0x8b35
  ▼ Flags: 0x8583 Standard query response, No such name
    1... .. = Response: Message is a response
    .000 0... .. = Opcode: Standard query (0)
    .... 1... .. = Authoritative: Server is an authority for domain
    .... 0... .. = Truncated: Message is not truncated
    .... 1... .. = Recursion desired: Do query recursively
    .... 1... .. = Recursion available: Server can do recursive queries
    .... 0... .. = Z: reserved (0)
    .... 0... .. = Answer authenticated: Answer/authority portion was not authenticated by the server
    .... 0... .. = Non-authenticated data: Unacceptable
    .... 0011 = Reply code: No such name (3)
  Questions: 1
  Answer RRs: 0
  Authority RRs: 1
  Additional RRs: 0
  > Queries
  > Authoritative nameservers
  [Request In: 5]
```

ID: 标识会话

flags: 标志位

- 第1位:标识消息类型(0是请求,1是响应)
- 第2~5位: opcode查询种类
- 第6位:标识是否是一个权威应答
- 第7位:一个UDP报文为512字节,指示是否截断超过的部分
- 第8位:是否请求递归
- 第9位:允许递归标识
- 第10-12位:保留位
- 第13~16位:应答码(0没有错误,1格式错误,2服务器错误,3名字错误,4服务器不支持,5拒绝,6-15保留)

祖国 荣誉 责任

第七讲 DNS协议



DNS报文格式

TCP.pcapng [ESW1 FastEthernet0/0 to R1 FastEthernet0/0]

```
> Frame 7: 137 bytes on wire (1096 bits), 137 bytes captured (1096 bits) on interface \Device\NPF_{00C0FC05-97D0-4...}
> Ethernet II, Src: RuijieNetwor_51:32:56 (c0:b8:e6:51:32:56), Dst: Intel_ef:2d:10 (18:56:80:ef:2d:10)
> Internet Protocol Version 4, Src: 202.200.123.2 (202.200.123.2), Dst: 10.103.123.219 (10.103.123.219)
> User Datagram Protocol, Src Port: 53, Dst Port: 50047
√ Domain Name System (response)
  Transaction ID: 0x8b35
  √ Flags: 0x8583 Standard query response, No such name
    1... .. = Response: Message is a response
    .000 0... .. = Opcode: Standard query (0)
    .... 1... .. = Authoritative: Server is an authority for domain
    .... 0... .. = Truncated: Message is not truncated
    .... 1... .. = Recursion desired: Do query recursively
    .... 1... .. = Recursion available: Server can do recursive queries
    .... 0... .. = Z: reserved (0)
    .... 0... .. = Answer authenticated: Answer/authority portion was not authenticated by the server
    .... 0... .. = Non-authenticated data: Unacceptable
    .... 0011 = Reply code: No such name (3)
  Questions: 1
  Answer RRs: 0
  Authority RRs: 1
  Additional RRs: 0
> Queries
> Authoritative nameservers
\[Request In: 5\]
```

Questions:请求段的问题记录数

Answer RRs:回答段中的应答记录数

Authority RRs:授权段中的授权记录数

Additional RRs:附加段中的附加记录数

DNS高速缓存

每个域名服务器都维护一个**高速缓存**，存放最近用过的名字以及从何处获得名字映射信息的记录。

可大大减轻根域名服务器的负荷，使互联网上的 DNS 查询请求和**回答报文**的数量大为减少。

为保持高速缓存中的内容正确，域名服务器应为**每项内容设置计时器**，并处理超过合理时间的项（例如，每个项目只存放两天）。

DNS高速缓存

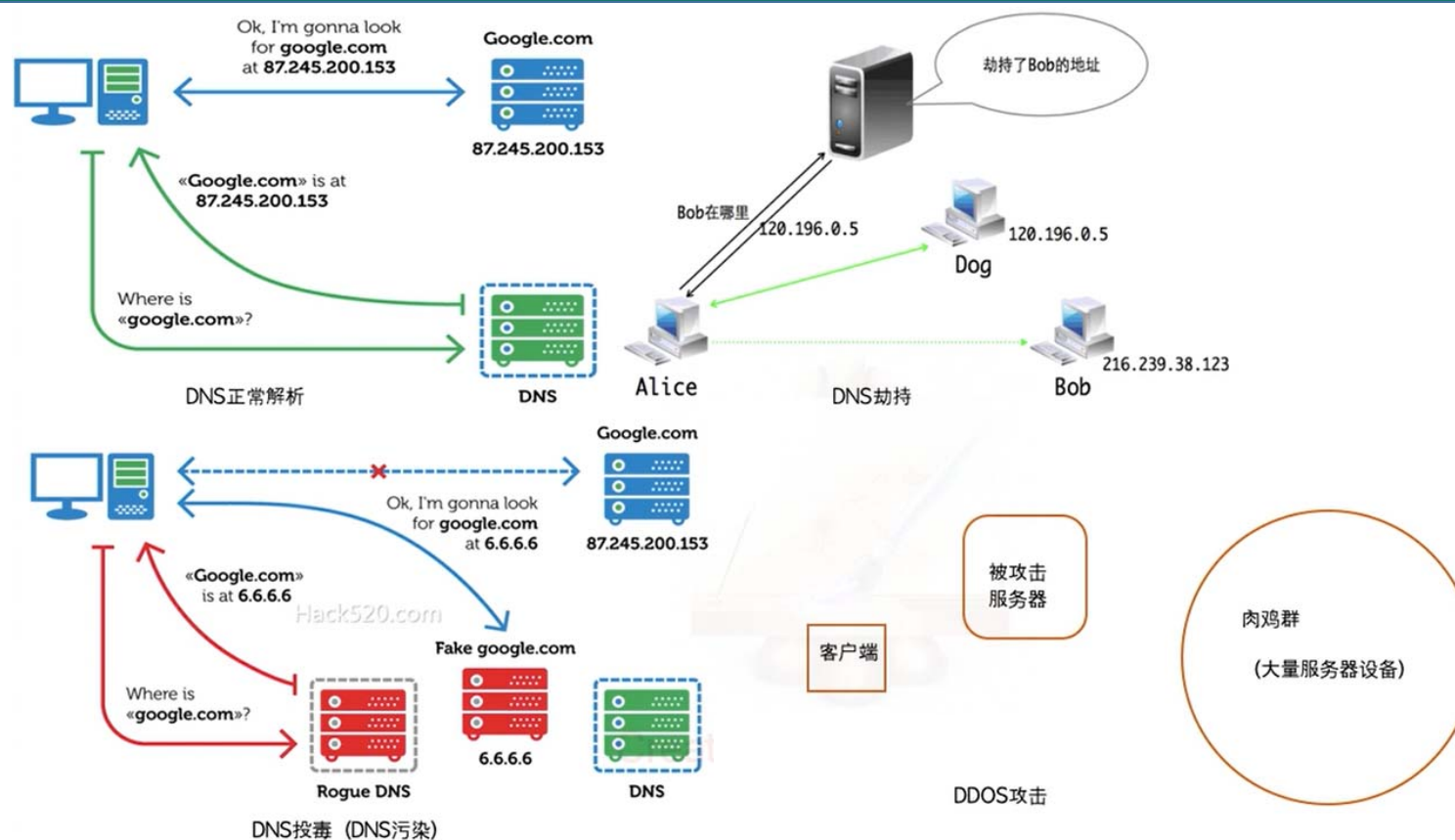
当权威域名服务器回答一个查询请求时，在响应中指明绑定有效存在的时间值。

增加此时间值可减少网络开销，而减少此时间值可提高域名转换的准确性。

解决了客户频繁向服务器请求解析不存在的域名问题。

第七讲 DNS协议

DNS攻击



DNS防御

DNS欺骗攻击是**很难防御的**，因为这种攻击大多数本质都是**被动的**。通常情况下，除非发生欺骗攻击，否则用户不可能知道自己的DNS已经被欺骗，只是打开的网页与用户想要看到的网页有所不同。在很多针对性的攻击中，用户都无法知道自己已经将网上银行账号信箱输入到错误的网址，直到接到银行的电话告知其帐号已购买某某高价商品时用户才会知道。不过，通过借助一些安全策略，还是可以加强其安全性的。

DNS防御

绑定IP地址和MAC地址

DNS欺骗前提也需要ARP欺骗成功。所以，首先做好对ARP欺骗攻击的防范，也就使得DNS欺骗攻击无从下手。因此，用户也可以使用MAC地址和IP地址静态绑定来防御DNS欺骗的发生。当客户机每次向DNS服务器发出查询申请后，就会检测DNS服务器响应的应答数据包中的MAC地址是否与存储器中的MAC地址相同。如果不同，则很有可能该网络中的DNS服务受到DNS欺骗攻击。这种方法有一定的不足，因为如果局域网内部的客户主机也保存了DNS服务器的MAC地址，仍然可以利用MAC地址进行伪装欺骗攻击。

DNS防御

直接使用IP地址访问

对个别信息安全等级要求十分严格的Web站点尽量不要使用DNS进行解析。大部分DNS欺骗攻击都是计划窃取客户的私密数据。因此，当访问需要严格保密信息的站点时，可以直接使用IP地址访问，而不是通过DNS解析。这样，就可以避免DNS欺骗攻击。

DNS防御

不要依赖DNS服务

在高度敏感和安全的系统中，用户通常不会在这些系统上浏览网页，最好不要使用DNS服务。如果用户有软件依赖于主机名来运行，那么可以在设备主机文件里手动指定。

其中, Linux系统的 HOSTS文件保存在/etc/ hosts中

Windows的 HOSTS文件保存在C: Windows system32 \driversetc
中。其格式为每行一条记录,即 “IP地址域名

DNS防御

对DNS应答包进行检测

在DNS欺骗攻击中，客户端会接收到至少两个DNS的数据响应包，一个是真实的数据包，另一个是攻击数据包。欺骗攻击数据包为了抢在真实应答包之前回复给客户端，它的信息数据结构与真实的数据包相比十分简单，只有应答域，而不包括授权域和附加域。因此，可以通过监测DNS响应包，遵循相应的原则和模型算法对这两种响应包进行分辨，从而避免虚假数据包的攻击。

小结

✓ DNS协议